

SERVIDOR APACHE



Redes de Datos 2018
Lic. Juan Francisco Bosco
Fa.CE.NA
Universidad Nacional del Nordeste

Contenido



Historia y Concepto



Instalacion Win/Linux



Configuración



Lectura de Logs

¿Que es Apache?

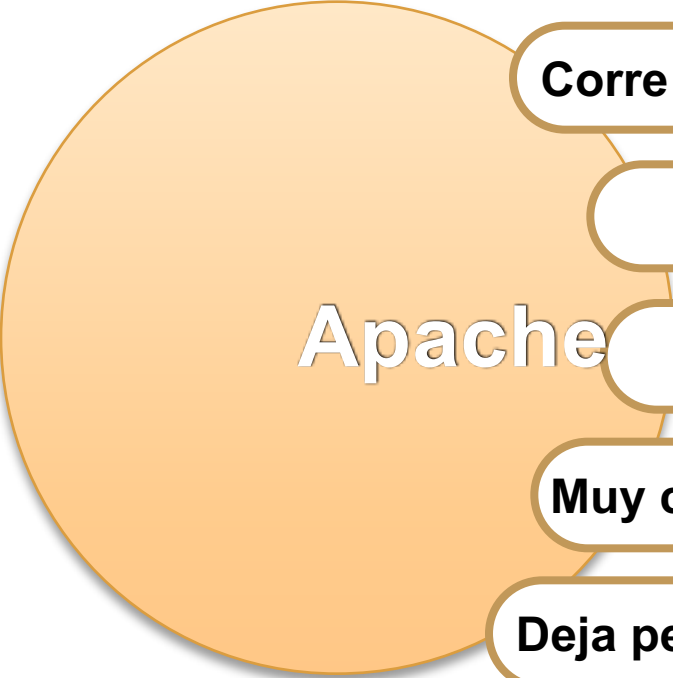
El servidor HTTP Apache es un servidor web HTTP de código abierto para plataformas Unix (BSD, GNU/Linux, etc.), Microsoft Windows, Macintosh y otras, que implementa el protocolo HTTP/1.1 (RFC 2616)

Es uno de los servidores web mas populares de Internet

Historia

- La historia de Apache se remonta a febrero de 1995, donde empieza el proyecto del grupo Apache, el cual esta basado en el servidor httpd de la aplicación original de NCSA. El desarrollo de esta aplicación original se estancó por algún tiempo tras la marcha de Rob McCool por lo que varios webmaster siguieron creando sus parches para sus servidores web hasta que se contactaron vía email para seguir en conjunto el mantenimiento del servidor web, fue ahí cuando formaron el grupo **Apache**.
- Fueron Brian Behlendorf y Cliff Skolnick quienes a través de una lista de correo coordinaron el trabajo y lograron establecer un espacio compartido de libre acceso para los desarrolladores
- El día 1 de diciembre del año 1995, apareció Apache 1.0, que incluía abundante documentación y muchas mejoras en forma de módulos que se podían incrustar

Características



Apache

Corre en una multitud de Sistemas Operativos

Gratuita y código abierto

Altamente configurable de diseño modular.

Muy configurable en la creacion y gestion de Logs

Deja personalizar la resp. ante los posibles errores

Configuración



Configuración

- Determinar el puerto
- Document Root
- Grupo y Usuario
- Permitir o Denegar Acceso a Directorios
- Impedir enlaces simbólicos y despliegue de directorio
- Borrar información de Version y Módulos instalados.
- Crear páginas de Errores 404–Not Found, 403–Forbidden
- Autenticación Básica: httpasswd
- Lectura y formato de Logs – Error_logs y access_logs

ARCHIVO DE CONFIGURACION

Los Archivos de configuración de Apache se encuentran en la carpeta /etc/apache2

- Apache esta configurado por directivas en un archivo de texto plano
- El principal archivo de configuración es llamado httpd.conf or apache2.conf
- El nombre de este archivo puede ser cambiado en la compilación de Apache.
- Otras configuraciones puede ser agregadas en el archivo principal con la directiva **include**
 - **ports.conf**: Donde estará haciendo Listen Apache. (Sockets)
 - **conf.d/**: Controla aspectos específicos de Apache. Security SSL etc
 - SERVERSIGNATURE (HARDENING)
 - **sites-available**: Contiene todos los Virtual Host
 - **sites-enabled**: Los virtual host que están siendo utilizado

Determinar el puerto

El puerto 80 está establecido al protocolo HTTP y el 443 por el protocolo HTTPS, por lo que apache lo usa como default .

Esta característica se puede cambiar en el archivo ports.conf

- ¿Por que es necesario cambiar de puerto por default?

Determinar el puerto

La directiva **Listen** le indica al servidor que acepte peticiones entrantes solamente en los puertos y en las combinaciones de puertos y direcciones que se especifiquen. Si solo se especifica un número de puerto en la directiva **Listen** el servidor escuchará en ese puerto, en todas las interfaces de red de la máquina

- **Listen 80**

Para hacer que el servidor acepte conexiones en dos interfaces de red y puertos específicos, use

- **Listen 192.170.2.1:80**
- **Listen 192.170.2.5:8000**

DOCUMENTROOT – Directorio principal visible desde la Web

Esta directiva especifica el directorio desde el cual el HTTPD servirá los ficheros

Esta directiva se llama **DocumentRoot**. Para cambiarla nos dirigimos a la línea.

- **DocumentRoot “/home/francisco/public_html”**

Esto significa que una petición a www.myhost.com/index.php equivaldría `/home/francisco/public_html/index.php`

Grupo y Usuario

El demonio **Apache** ni bien es levantado, es ejecutado por el usuario root, por el motivo de que el puerto donde se escucha es el 80, luego es pasado a un usuario que se define en el **user.conf**. Este ultimo es un usuario con pocos privilegios, esto se realiza por motivos de que si un atacante rompe alguna vulnerabilidad del host, este tenga los mínimos privilegios posibles. (**Principio de Seguridad de Menos Privilegio**)

Para realizar esto según **Ivan Ristic** en su libro “**Apache Security**”, comenta que debemos crear un usuario y un grupo con estas 2 líneas siguientes.

```
#groupadd httpd
```

```
#useradd httpd -g httpd -d /dev/null -s /sbin/nologin.
```

Grupo y Usuario

“Apache nunca debería correr como root”

Siguiendo con el ejemplo anterior, modificaríamos el **ports.conf**

user httpd

group httpd

Otras cuentas que se suelen usar son: **nobody y www-data**

Permitir o Denegar Acceso a Directorios

Las directivas <Directory> y </Directory> se usan para englobar un grupo de directivas que se aplicarán solamente al directorio especificado y a sus subdirectorios. Puede incluir a cualquier directiva cuyo uso esté permitido en un contexto <directory>.

allow: Allow especifica cual cliente pueda acceder al directorio dado. El solicitante puede ser un nombre de dominio, una dirección IP, una dirección IP parcial, un par de red/máscara de la red, etc. El directorio **DocumentRoot** esta configurado para permitir (Allow) peticiones desde todos (all), es decir, que todos tienen acceso.

deny: Deny funciona igual que Allow, excepto que especifica a quién se le niega el acceso. **DocumentRoot** no es configurado para negar (Deny) peticiones a ninguno por defecto.

order: La directiva Order controla el orden en el cual las directivas allow y deny son evaluadas. El servidor es configurado para evaluar las directivas Allow antes de las directivas Deny para el directorio **DocumentRoot**.

Permitir o Denegar Acceso a Directorios

Con estas directivas, podemos crear configuración para permitir o denegar a una ip, dominio o red.

```
<Directory /home/francisco/www/vulntotex>
```

```
    Order deny,allow
```

```
    Deny from all
```

```
    Allow from 192.168.200.0/24
```

```
</Directory>
```



¡Acceso prohibido!

Usted no tiene permiso de acceder al objeto solicitado. Existe la posibilidad de que este protegido contra lectura o que no haya podido ser leído.

Por favor contacte con el [webmaster](#) en caso de que usted crea que existe un error en el servidor.

Error 403

[localhost](#)

jue 01 mar 2012 23:53:27 ART

Apache/2.2.14 (Unix) DAV/2 mod_ssl/2.2.14 OpenSSL/0.9.8l PHP/5.3.1 mod_apreq2-20090110/2.7.1 mod_perl/2.0.4 Perl/v5.10.1



Nombre:

Contraseña:

Ingresar

Registrarse

Permitir o Denegar Acceso a Directorios

Otros ejemplos

order Deny, allow

allow from redes.unne.edu.ar sistemas.unne.edu.ar seguridad.unne.edu.ar

deny from all

order Deny, allow

allow from unne.edu.ar

deny from all

Order Deny,Allow

Allow from 176.16.0.0/16

Deny from all

Impedir enlaces simbólicos y despliegue de directorio

La directiva **Options** controla qué funcionalidades del servidor están disponibles en un directorio en particular

Si la directiva esta como NONE, ninguna funcionalidad estara activa y con ALL lo contrario. Las dos directivas que vamos a ver son

FollowSymLinks

El servidor seguirá los enlaces simbólicos en este directorio

SymLinksIfOwnerMatch

El servidor seguirá los enlaces simbólicos en los que el fichero o directorio final pertenezca al mismo usuario que el enlace.

Indexes

Si se produce una petición a una URL que se corresponde con un directorio, y no hay DirectoryIndex (por ejemplo, index.html) en ese directorio, entonces mod_autoindex devolverá una lista con los contenidos del directorio.

Mas info <http://httpd.apache.org/docs/2.0/mod/core.html#options>

Impedir enlaces simbolicos y despliegue de directorio

El problema de poder ejecutar enlaces simbolicos es que apache puede leer archivos fuera del DocumentRoot, por seguridad la opcion **FollowSymlinks** debe estar desactivada.

Otro tema importante es la opcion **Indexes**, con esta opcion hay que tener cuidado cuando utilizarla y cuando no, ya que si Apache no encuentra un archivo index.htm, index.html etc. Desplegaria todo el contenido del directorio pudiendo revelar informacion sensible

<Directory /home/francisco/www>

Options -Indexes -FollowSymlinks

</Directory>

Index of /apache

Name	Last modified	Size	Description
 Parent Directory		-	
 httpd.conf	23-ene-2010 13:39	18K	
 index.php.bak	17-may-2010 22:37	2	
 rewrite-es.php	14-may-2010 01:03	1.6K	

Apache/2.2.12 (Unix) DAV/2 mod_ssl/2.2.12 OpenSSL/0.9.8k PHP/5.3.0 mod_apreq2-20051231/2.6.0 mod_perl/2.0.4 Perl/v5.10.0 Server at l

Mozilla Firefox

Archivo Editar Ver Historial Marcadores Herramientas Ayuda

http://localhost/pass directorio raiz apache

Más visitados Getting Started Latest Headlines Gmail - Recibidos (... Personal Te Convi... Traductor de Google

directorio raiz apache httpd.cc Buscar Compartir Sidewiki Marcadores Traducir Acceder

Personal Te ... directorio <D... directorio raiz... http://...st/pass Directivas de ... El fichero htt... Compilación ... Directivas de ... http...pass

```
root:x:0:0:root:/root:/bin/bash
daemon:x:1:1:daemon:/usr/sbin:/bin/sh
bin:x:2:2:bin:/bin:/bin/sh
sys:x:3:3:sys:/dev:/bin/sh
sync:x:4:65534:sync:/bin:/bin/sync
games:x:5:60:games:/usr/games:/bin/sh
man:x:6:12:man:/var/cache/man:/bin/sh
lp:x:7:7:lp:/var/spool/lpd:/bin/sh
mail:x:8:8:mail:/var/mail:/bin/sh
news:x:9:9:news:/var/spool/news:/bin/sh
uucp:x:10:10:uucp:/var/spool/uucp:/bin/sh
proxy:x:13:13:proxy:/bin:/bin/sh
www-data:x:33:33:www-data:/var/www:/bin/sh
backup:x:34:34:backup:/var/backups:/bin/sh
list:x:38:38:Mailing List Manager:/var/list:/bin/sh
irc:x:39:39:ircd:/var/run/ircd:/bin/sh
gnats:x:41:41:Gnats Bug-Reporting System (admin):/var/lib/gnats:/bin/sh
nobody:x:65534:65534:nobody:/nonexistent:/bin/sh
libuuid:x:100:101::/var/lib/libuuid:/bin/sh
syslog:x:101:102::/home/syslog:/bin/false
messagebus:x:102:106::/var/run/dbus:/bin/false
hplip:x:103:7:HPLIP system user,,,:/var/run/hplip:/bin/false
avahi-autoipd:x:104:110:Avahi autoip daemon,,,:/var/lib/avahi-autoipd:/bin/false
avahi:x:105:111:Avahi mDNS daemon,,,:/var/run/avahi-daemon:/bin/false
haldaemon:x:106:113:Hardware abstraction layer,,,:/var/run/hald:/bin/false
polkituser:x:107:115:PolicyKit,,,:/var/run/PolicyKit:/bin/false
kernoops:x:108:65534:Kernel Oops Tracking Daemon,,,:/bin/false
saned:x:109:116::/home/saned:/bin/false
```

Buscar: allow Anterior Siguiente Resaltar todo Coincidir mayúsculas

FoxyProxy: Deshabilitado

presentacion - Mozilla Firefox .htaccess - Kate www - bash enlaccessimbolic apache.ppt - Op 01:35 Jun, 27 May

Borrar informacion de Version y Modulos instalados.

Apache tiene formas de poder borrar la informacion en las paginas de errores o cabeceras HTTP, para no dar tanta informacion a algun curioso dando vueltas.

La directiva que realiza esta accion es **ServerTokens**. Esta nos permite poder granular dicha informacion. Por defecto dicha configuracion viene con la opcion “full”, que revela informacion interesante.

**Apache/2.2.12 (Unix) DAV/2 mod_ssl/2.2.12 OpenSSL/0.9.8k
PHP/5.3.0 mod_apreq2-20051231/2.6.0 mod_perl/2.0.4
Perl/v5.10.0**

Colocando la directiva ServerTokens a “Prod”, Solo mostrara el producto y filtraremos mucha informacion.

ServerTokens Prod

Magno:/home/magno/Linux a fondo# telnet localhost 80

Trying ::1...

Connected to localhost.

Escape character is '^['.

HEAD / HTTP/1.0

HTTP/1.1 200 OK

Date: Tue, 18 May 2010 02:48:22 GMT

Server: Apache/2.2.12 (Unix) DAV/2 mod_ssl/2.2.12 OpenSSL/0.9.8k PHP/5.3.0 mod_apreq2-20051231/2.6.0 mod_perl/2.0.4 Perl/v5.10.0

Connection: close

Content-Type: text/html; charset=ISO-8859-1

Connection closed by foreign host.

Magno:/home/magno/Linux a fondo#

Borrar información de Version y Módulos instalados.

Esta directiva permite borrar la información en las páginas de
encabezados HTTP, para no dar tanta información a otros
usuarios o bots.

La directiva que realiza esta acción es ServerTokens. Esta nos permite
poder controlar dicha información, por defecto dicha configuración
viene con la opción "Full", que revela información interesante.

Colocar la directiva ServerTokens a Prod. Solo muestra el producto.

Para Prod

Magno:/home/magno/Linux a fondo# telnet localhost 80

Trying ::1...

Connected to localhost.

Escape character is '^]'.

HEAD / HTTP/1.0

HTTP/1.1 200 OK

Date: Tue, 18 May 2010 02:55:00 GMT

Server: Apache

Connection: close

Content-Type: text/html; charset=ISO-8859-1

Connection closed by foreign host.

Magno:/home/magno/Linux a fondo#

Borrar informacion de Version y Modulos instalados.

Modificar el archivo **server/core.c.**

```
static void  
set_banner(apr_pool_t *pconf)  
{  
    if (ap_server_tokens ==  
    SrvTk_PRODUCT_ONLY) {  
  
    ap_add_version_component(pconf,  
    "Microsoft-ISS/5.0");
```

Crear paginas de Errores 404–Not Found, 403-Fordibben

En el protocolo HTTP como en la mayoría de todos, tenemos distintos estados que arroja el servidor al cliente informando la respuesta.

Codio de Estados HTTP

- 1xx Respuestas informativas:** Esta clase de código de estado indica una respuesta provisional.
- 2xx Peticiones Correctas:** Esta clase de código de estado indica que la petición fue recibida correctamente, entendida y aceptada.
- 3xx Redirecciones:** El cliente tiene que tomar una acción adicional para completar la petición.
- 4xx Errores del Cliente:** La solicitud contiene sintaxis incorrecta o no puede procesarse.
- 5xx Errores del Servidor:** El servidor falló al completar una solicitud aparentemente válida.

Crear paginas de Errores 404—Not Found, 403-Fordibben

Directiva ErrorDocument: El servidor devuelve al cliente si se produce algún error.

```
<Directory "/home/magno/www/zambonet">  
ErrorDocument 500 http://foo.example.com/cgi-bin/tester  
ErrorDocument 404 "No se encuentra la pagina"  
ErrorDocument 403 "No puedes Acceder a esta Pagina"  
</Directory>
```

Autenticacion Basica: httpasswd

La autenticacion basica consiste en poder proteger algun directorio pidiendo un usuario y contraseña, si colocamos correctamente los dos datos, el servidor nos arrojará un código 200 OK, permitiendo el acceso protegido, en caso contrario nos arrojará un 401 ACCESO NO AUTORIZADO.



Autenticacion Basica: htpasswd

Para poder utilizar esta característica necesitamos crear un archivo llamado `.htpasswd`, que es el que contendrá el usuario y la contraseña en el formato estándar

`user:pass`

Para crear el archivo vamos a utilizar un binario llamado `htpasswd`, el cual desde `lampp` se encuentra en `/opt/lampp/bin/htpasswd`.

Creamos un usuario magno y contraseña 123456 (La contraseña te la pide en ejecución del binario)

`./htpasswd -cm /home/magno/www/.htpasswd magno`

El parámetro “c”, crea un nuevo archivo, “m” fuerza a que la encriptación sea en MD5 y lo guarda en el path `/home/magno/.htpasswd`

`[.htpasswd]`

`magno:$apr1$EwtgbQPt$8srrX40QrKKoRihwCrsA1/`

Autenticacion Basica: httpasswd

¿Que es son los archivos .htaccess?

Un archivo oculto, que contiene una o más directivas de configuración, se coloca en un directorio determinado, y las directivas se aplican a ese directorio, y todos los subdirectorios del mismo. ALLowOverride controla qué directivas se pueden situar en los ficheros .htaccess.

Cuando usarlos

Se recomienda no utilizarlos, pero es esencial cuando no tenemos permiso de escribir en el archivo httpd.conf. Nos da la ventaja de poder colcar configuraciones sin necesidad de ser el administrador del host

Por que no usarlos

Rendimiento: El archivo .htaccess se carga cada vez que un documento se solicita.

Seguridad: se esta permitiendo a los usuarios modificar la configuración del servidor.

Autenticacion Basica: httpasswd

Creamos un archivo .htaccess con esta caracteristica

```
AuthUserFile /home/magno//.htpasswd  
AuthName "Herramientas priv8"  
AuthType Basic  
require user magno
```

AuthUserFile: Especifica la ruta de donde ir a buscar el archivo de contraseñas

AuthName: es una cadena de texto para el cuadro de dialogo del Login

AuthType: especifica el modo de autentificacion.

Se requiere autenticación

http://127.0.0.1 solicita un usuario y contraseña. El sitio dice: "Area Restringida ZamboNet"

Nombre de usuario:

Contraseña:

Cancelar Aceptar

Lectura y formato de Logs (Tema 8)

Apache tiene una alta configuracion de los archivos de Logs. Estos archivos se encuentran en la ruta `/var/log/apache2/`, pero en este paquete LAMPP con el que trabajamos se encuentran en `/opt/lampp/logs`

Como primer medida de seguridad tenemos que asegurarnos que los archivos de Log solo tengan permiso de escritura del usuario ROOT.

```
-rw-r--r-- 1 root  root 179249 2010-06-06 00:50 access_log
-rw-rw-r--1root  root  39792 2010-06-06 00:50  error_log
-rw-r--r-- 1 root  root   670 2010-06-06 00:50      ip_log
```

Lectura y formato de Logs - Error Log

El registro de errores del servidor, cuyo nombre y ubicación se especifica en la directiva **ErrorLog**, es el más importante de todos los registros.

El primer lugar donde tiene que mirar cuando surja un problema al iniciar el servidor o durante su operación normal, porque con frecuencia encontrará en él información detallada de qué ha ido mal y cómo solucionar el problema.

[Fri May 28 00:30:51 2010] [error] [client 190.189.24.101] Symbolic link not allowed or link target not accessible: /home/magno/www/pass

Lectura y formato de Logs - Access Log

Lleva los registros de acceso al servidor, las directivas que se manejan en este contexto son **CustomLog** y **LogFormat**.

LogFormat: Nos permite crear los formatos de los logs para almacenarlos. El formato consiste en una serie de directivas con tantos por ciento, cada una de las cuales le dice al servidor que registre una determinada información en particular.

e.g.

LogFormat "%h %u %t \"%r\" %>s %b" common ← **nickname**

formato

CustomLog: crea un nuevo fichero de registro usando el apodo definido.

e.g.

CustomLog logs/access_log common

Lectura y formato de Logs - Access Log

127.0.0.1 magno [14/Jun/2010:17:21:27 -0300] "GET /zambonet/ HTTP/1.1" 200 5968

- 127.0.0.1 (%h): Direccion IP
- magno (%u): Identificador del Usuario
- [14/Jun/2010:17:21:27 -0300] (%t): Hora de peticion del servidor
- "GET /zambonet/ HTTP/1.1" ("%r"): Peticion del cliente
- 200 (%>s):Codigo de estado
- 5968 (%b): Bytes enviados

Lectura y formato de Logs - Access Log

Para crear nuestro archivo log personalizado realizamos este paso

```
#cd /var/logs/apache2  
#touch ip_log  
#chmod 644 ip_log
```

Editamos el archivo httpd.conf colocando y nos dirigimos a la seccion de log y copiamos lo siguiente

```
LogFormat "%h %U %o %>" supe  
CustomLog logs/ip_log supe
```

Nos guardara las IP %h, y el User Agent %U del navegador del cliente.

BIBLIOGRAFIA

- <https://httpd.apache.org/docs/2.0/es/configuring.html#main>
- <https://httpd.apache.org/docs/2.0/es/mod/core.html#directory>

SERVIDOR APACHE



Bibliografia:

Seguridad en Apache – Ivan Ristik

**Redes de Datos 2016
Lic. Juan Francisco Bosco
Fa.CE.NA
Universidad Nacional del Nordeste**